

Разбор APK: Big Gold Win

Пакет: com.gold.stack.app • версия 1.1 (код 2) • разработчик: K' ELEGANCE UNI • файл: agent_base.apk • название в Play «Big Gold Win», application-label внутри APK «Big Gold Win»

SDK / стек

Название приложения	Big Gold Win
Android Gradle Plugin	9.2.1
minSdk	32
targetSdk	36
Kotlin	да (kotlin-stdlib + kotlin.coroutines; номер версии Kotlin в APK не записан)
Web View	да
Custom Tabs	да
Рекламные сети	нет
Аналитика	Adjust 5.8.0, Firebase Cloud Messaging 24.1.0, Firebase Installations, Google DataTransport (CCT), Google Advertising ID (play-services-ads-identifier), Google Play Install Referrer
Permissions	android.permission.INTERNET, android.permission.ACCESS_NETWORK_STATE, com.google.android.gms.permission.AD_ID, android.permission.CAMERA, android.permission.POST_NOTIFICATIONS, android.permission.WAKE_LOCK, com.google.android.c2dm.permission.RECEIVE, com.gold.stack.app.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION, com.google.android.finsky.permission.BIND_GET_INSTALL_REFERRER_SERVICE, com.android.vending.CHECK_LICENSE
Libraries	androidx.appcompat, androidx.core, androidx.activity, androidx.fragment, androidx.lifecycle, androidx.constraintlayout, androidx.recyclerview, androidx.viewpager2, androidx.savedstate, androidx.emoji2, androidx.startup, androidx.profileinstaller, androidx.annotation, androidx.versionedparcelable, androidx.browser (Custom Tabs), com.google.android.material, kotlin-stdlib, kotlin.coroutines, kotlin.serialization.json, com.google.firebase (messaging 24.1.0, installations, common, components, datatransport, encoders), com.google.android.datatransport (CCT), com.google.android.gms (base 18.5.0, basement 18.4.0, ads-identifier 18.2.0, cloud-messaging 17.2.0, stats 17.0.2, tasks 18.2.0), com.android.installreferrer, com.adjust.sdk 5.8.0, com.github.megatronking.stringfog (XOR-обфускация строк), com.pairip (licensecheck, VM-защита), org.json
Подозрительные домены	quantixmatrix.digital
SharedPreferences	два файла настроек. «stack_state_slab»: entry_link (ссылка из push-сообщения либо метка «stage_done»), device_mark (рекламный номер устройства либо случайный номер), seed_mark (постоянный случайный номер), source_trace (метка источника установки), campaign_mark (рекламный номер Adjust), campaign_trace (метки кампании Adjust). «stack_state_vault»: best_tower_mark, gold_piece_count, guide_line_shown, spark_burst_shown (настройки и рекорд обычной игры).
Есть ли клоака	да
Подозрительные слова	url, returnUrl, browser_fallback_url, entry_link, stage_done, SignalAlertGate, RemoteStageScreen, dynamicStateManager, device_mark, seed_mark, source_trace, campaign_mark, campaign_trace, onClickedView, termsfeed, live, googlepay://, tez://, intent://

Проверка домена: quantixmatrix.digital

Формат как на VirusTotal → Security vendors' analysis, в конце три доп. пункта.

Домен	quantixmatrix.digital
VirusTotal URL	https://www.virustotal.com/gui/domain/quantixmatrix.digital
Детекции	нет
Куда редиректит	нет (без редиректа); https://quantixmatrix.digital/ отвечает 403 Cloudflare, https://www.quantixmatrix.digital/ — 200 без цепочки редиректов
Что выводит (кратко)	title: Welcome to nginx. Стандартная заглушка nginx («If you see this page, the nginx web server is successfully installed and working. Further configuration is required.»). Тело POST/GET на apex — пустое (Cloudflare 403).
Где припаркован	регистратор: NameCheap, Inc.; DNS: Cloudflare (vick.ns.cloudflare.com, blair.ns.cloudflare.com)

Какие данные собираются

- рекламный номер устройства
- постоянный случайный номер приложения
- метка источника установки
- номер для push-сообщений
- рекламный номер Adjust
- метки рекламной кампании Adjust
- производитель телефона
- модель телефона
- строка браузера телефона
- имя пакета приложения

Как собираются

Всё начинается сразу при запуске: первым и единственным экраном, который открывается по значку приложения, идёт RemoteStageScreen — тёмная заставка с крутящимся значком, а не сама игра. Пока человек видит эту заставку, приложение в фоне запрашивает у системы Android рекламный номер устройства; если человек запретил рекламный номер или система выдаёт пустой номер, приложение один раз придумывает случайный номер и сохраняет его в своих настройках, чтобы дальше узнавать этот телефон. Тем же способом заводится второй постоянный случайный номер (склеенные два случайных значения). У магазина Google Play приложение забирает метку источника установки — по ней видно, из какой рекламы пришёл человек. У службы push-сообщений Firebase запрашивается персональный номер этого телефона для отправки сообщений, а у рекламной системы Adjust — её внутренний номер устройства и метки рекламной кампании (ожидание ответа ограничено примерно 15 секундами). Производитель и модель телефона берутся из системных данных и приводятся к одному виду (маленькие буквы, вместо любых лишних знаков — подчёркивание), а строка браузера телефона (техническое описание встроенного браузера, где указаны версия Android и модель) берётся у самого встроенного окна сайта. Имя пакета приложения читается у самого себя. Отдельного окна с вопросом или предупреждения человек не видит: единственное окно, которое может появиться, — это стандартный запрос на показ уведомлений на новых версиях Android, и он нужен как раз для того, чтобы приложение могло получить push-сообщение со ссылкой.

Куда отправляются

Сначала приложение тихо, без ведома человека, стучится на страницу своего приложения в Google Play (адрес <https://play.google.com/store/apps/details?id=com.gold.stack.app&hl=en>) — просто чтобы посмотреть, отвечает ли эта страница. Затем собранные сведения складываются в один компактный двоичный свёрток и шифруются прямо на телефоне: пароль «dynamicStateManager» жёстко вписан в код, ключ получается перебором PBKDF2 (10

000 повторов), шифрование AES-GCM, к результату спереди приклеиваются случайная соль и вектор. Этот зашифрованный свёрток уходит методом POST на один единственный адрес — <https://quantixmatrix.digital/> — с типом «двоичные данные» и с подставленной строкой браузера телефона в заголовке. Запасных адресов в коде нет, адрес не собирается из кусков по частям, но он спрятан: в файле он лежит в виде набора байт, зашифрованных простым XOR (библиотека StringFog), и превращается в обычный текст только во время работы. Ни экрана загрузки с этим адресом, ни каких-либо сообщений человек не видит — обмен идёт полностью в фоне, пока крутится значок на заставке.

Как фильтруются пользователи

Первый отбор приложение делает само, на телефоне: если страница приложения в Google Play не ответила кодом 200 (нет интернета, страница недоступна или закрыта для этой страны), приложение сразу уходит в обычный режим и никакой проверки не делает. Если страница доступна — приложение отправляет собранные признаки и дальше решение принимает сервер: никаких списков стран, языков, признаков бота или эмулятора внутри приложения нет, есть только отправка признаков и разбор кода ответа. Фактически человека узнают по рекламному номеру устройства, по метке источника установки и по меткам рекламной кампании Adjust — то есть по тому, из какой рекламы он пришёл, а также по производителю и модели телефона и по строке браузера. Отдельно важен номер для push-сообщений: он позволяет владельцу схемы выбрать конкретных людей и отправить ссылку не всем сразу, а адресно и в любой момент после установки. Есть и обратная связь от самой страницы: в открытое окно сайта добавлен мостик с именем «onClickedView», и загруженная страница может сама скомандовать приложению переключиться на обычную игру. Дополнительно приложение помечает у себя «stage_done» — метку «этому телефону больше ничего не показывать», после которой обычный режим остаётся навсегда.

Что возвращается

От самого проверочного адреса приложение не читает ни текста, ни ссылок — из ответа берётся только его код. Если код в диапазоне 200–299, приложение не показывает ничего нового: заставка просто остаётся на экране, то есть телефон признан подходящим и ждёт команду. Если код в диапазоне 400–499, приложение записывает у себя метку «stage_done» и навсегда уходит в обычный режим. При любом другом ответе или ошибке связи человек в этот раз тоже получает обычное приложение. Сама ссылка приходит позже и другим путём — push-сообщением через Firebase: служба SignalAlertGate достаёт из сообщения поле «url», сохраняет его в настройках под именем «entry_link» и тут же выводит на передний план ту же заставку, которая эту ссылку и открывает. Если в push-сообщении поле «url» пустое, приложение показывает обычный режим. Сохранённая ссылка живёт в настройках и при следующих запусках открывается сразу, без всякой проверки.

Как показывается оффер или белая версия

Если ссылка получена, её открывают внутри самого приложения — во встроенном окне сайта на весь экран, вместо игры, ещё до того как человек увидит какое-либо меню. Окно настроено как полноценный браузер: разрешены скрипты, хранение данных сайта, файлы-метки сайта (в том числе сторонние), открытие дополнительных окон, загрузка файлов, выбор файлов с телефона и доступ к камере по запросу страницы (для этого и просится разрешение на камеру). Обычные ссылки http и https остаются внутри этого окна, а ссылки на приложения-кошельки (googlepay://, tez://) и служебные ссылки intent:// передаются наружу, в установленные приложения; страницы Google Pay открываются через внешнее окно браузера Chrome (Custom Tabs). Какая именно страница загрузится, в APK не записано: её адрес целиком задаёт сервер, поэтому из кода видна только механика показа, а не содержимое страницы. Если страница отвечает ошибкой 400–499 или связь не устанавливается, приложение помечает «stage_done» и уходит в обычный режим. Если же

ссылки нет, человеку просто остаётся обычное приложение.